

Login and password reset

1. A registered user must sign in using a valid email address and password and arrive at the account dashboard.
2. Invalid credentials must show a generic error without revealing whether the email address exists.
3. Passwords must contain between 8 and 64 characters inclusive; values outside this range must be rejected.
4. After five consecutive failed sign-in attempts, the account must be locked for 15 minutes.
5. An unauthenticated user must not access the account dashboard and must be redirected to sign in.
6. A user may request a password reset with an email address; the response must not reveal whether an account exists.
7. A password-reset link must expire after 30 minutes and must be usable only once.
8. A successful password reset must invalidate existing sessions and allow sign-in with the new password only.
9. A user must not reset a different user's password using a modified reset token.
10. Blank email or password fields must show a clear validation message before submission.